# Glossar

Prof. Dr. Dirk Loomans

29. September 2026

**Vorlesungsskript · Grundlagen der Resilienz** · Cyber Security Management (B.Sc.), 1. Semester · Hochschule Mainz

*Vorbemerkung:* Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Das Glossar führt die Glossare der Sitzungen 3 und 4 sowie das OT- und KI-Glossar aus dem Skript zu Sitzung 9 zusammen. Die Angabe in Klammern verweist auf den Termin, in dem der Begriff eingeführt oder vertieft wird. Für die Klausur genügt es nicht, Begriffe zu definieren; sie müssen in Zusammenhänge eingeordnet werden.

## Abkürzungen

| Abkürzung | Bedeutung |
|---|---|
| AD | Active Directory – Verzeichnisdienst für Identitäten, Gruppen und Policies (Microsoft) |
| AZ | Availability Zone – separater Rechenzentrumsbereich innerhalb einer Cloud-Region |
| BCM | Business Continuity Management – Managementsystem zur Sicherstellung kritischer Geschäftsprozesse bei Störungen (BSI 200-4, ISO 22301) |
| BSI 200-4 | BSI-Standard 200-4 „Business Continuity Management“ mit Reifegradmodell |
| CDN | Content Delivery Network – geografisch verteiltes Netz zur resilienten Auslieferung von Web-Inhalten |
| CERT | Computer Emergency Response Team – operative Reaktionseinheit im Incident |
| CSIRT | Computer Security Incident Response Team – in der Praxis meist gleichbedeutend mit CERT (6) |
| CI/CD | Continuous Integration / Continuous Deployment – automatisierte Build-, Test- und Release-Pipelines |

| Abkürzung | Bedeutung |
|---|---|
| CISO | Chief Information Security Officer – strategische Verantwortung für Informationssicherheit und Cyber-Resilienz |
| DDoS | Distributed Denial of Service – Lastangriff, der Dienste durch Überlast unbenutzbar macht |
| DNS | Domain Name System – Namensauflösung, kritisch für die Erreichbarkeit fast aller Dienste |
| DPO | Data Protection Officer – Datenschutzbeauftragte Person (Art. 37–39 DSGVO) |
| DR | Disaster Recovery – Wiederanlauf von IT-Systemen nach gravierenden Störungen |
| ENISA | European Union Agency for Cybersecurity |
| HMI | Human Machine Interface – Bedienoberfläche von OT-Anlagen |
| HSM | Hardware Security Module – gesicherte Hardware zur Erzeugung und Verwaltung von Schlüsseln |
| IaC | Infrastructure as Code – Infrastruktur wird per Code definiert und automatisiert bereitgestellt |
| ICS | Industrial Control System – Überbegriff für SCADA, PLC und DCS |
| IdP | Identity Provider – authentifiziert Nutzer und stellt Tokens aus (z. B. Entra ID/Azure AD, Keycloak) |
| ISB | Informationssicherheitsbeauftragte Person – koordiniert das Sicherheitsmanagement, im öffentlichen Sektor und an Hochschulen häufig statt eines CISO (6) |
| KRITIS | Kritische Infrastrukturen (Energie, Wasser, Gesundheit, Finanzen u. a.) |
| MES | Manufacturing Execution System – Produktionsleitsystem zwischen OT und ERP |
| MTBF | Mean Time Between Failures – mittlere Zeit zwischen zwei Ausfällen |
| MTTR | Mean Time To Repair / Recover – durchschnittliche Wiederherstellungsdauer |
| OT | Operational Technology – Technik zur Steuerung physischer Prozesse |

| Abkürzung | Bedeutung |
|---|---|
| PLC | Programmable Logic Controller – Steuerungsrechner für Maschinen und Prozesse |
| RPO | Recovery Point Objective – maximal tolerierter Datenverlust in Zeit |
| RTO | Recovery Time Objective – maximal tolerierte Wiederherstellungsdauer |
| SCADA | Supervisory Control and Data Acquisition – Überwachung und Steuerung industrieller Prozesse |
| SEC | U.S. Securities and Exchange Commission – US-Börsenaufsicht; verlangt Pflichtmitteilungen (Form 8-K) auch zu wesentlichen Cybervorfällen (6) |
| SIEM | Security Information and Event Management – Aggregation und Korrelation von Sicherheitsereignissen |
| SIL | Safety Integrity Level – Maß für die Zuverlässigkeit von Safety-Systemen |
| SLA | Service Level Agreement – vertraglich zugesicherter Leistungsgrad |
| SOAR | Security Orchestration, Automation and Response |
| SOC | Security Operations Center – Überwachung und Erkennung |
| SPOF | Single Point of Failure – Einzelkomponente, deren Ausfall das Gesamtsystem lahmlegt |
| USV | Unterbrechungsfreie Stromversorgung (UPS) |
| WAF | Web Application Firewall – Schutz auf Anwendungsebene (Injection, XSS) |
| WORM | Write Once, Read Many – unveränderbare Speicherung |

## Begriffe der Cyber-Resilienz

**3-2-1-1-0-Regel** – Drei Kopien der Daten auf zwei Medientypen, eine davon außerhalb des Standorts, eine unveränderbar oder physisch getrennt, null Fehler im Restore-Test. „Außerhalb“ meint eine andere Schadensdomäne: anderes Netz, andere Konten, bei Cloud-Diensten eine andere Steuerungsebene (Fälle CloudNordic 2023, UniSuper 2024). (7)

**Air-Gap** – Trennung einer Sicherungskopie von der Produktion: physisch (ausgelagertes Band) oder logisch (zeitlich und technisch kontrollierter Zugang). Schützt gegen Löschung und Verschlüsselung über das Netz. (7)

**Availability Zone (AZ) / Multi-AZ-Deployment** – Eine AZ ist ein physisch getrenntes, logisch verbundenes Rechenzentrumssegment einer Cloud-Region mit eigener Strom-, Kühlungs- und Netzversorgung. Beim Multi-AZ-Deployment läuft ein Dienst gleichzeitig in mehreren AZs; fällt eine Zone aus, übernehmen die anderen, etwa über Load Balancer und synchron gespiegelte Datenbanken. Resilienz entsteht erst durch diese tatsächliche Verteilung. Multi-AZ schützt gegen den Ausfall eines Standorts, nicht gegen die Störung einer ganzen Region (→ Multi-Region-Design). (3)

**Backup (vs. Recovery)** – Die existierende Kopie von Daten oder Systemzuständen. Resilienz entsteht nicht durch das Vorhandensein, sondern durch die Fähigkeit, innerhalb der RTO/RPO-Ziele wiederherzustellen. „Backup ohne Restore-Test" ist Scheinsicherheit. (3, 4, 7)

**BCM** – Managementrahmen zur Sicherstellung kritischer Geschäftsprozesse während und nach Störungen. IT-Resilienz ist ein technischer Teilaspekt davon. (2, 3, 6)

**Break-Glass-Account** – Notfallkonto mit lokalem oder isoliertem Zugriff, das den Betrieb ermöglicht, wenn zentrale Identity-Provider ausgefallen oder kompromittiert sind. (3, 4)

**Chaos Engineering** – Systematisches Einbringen kontrollierter Störungen (Instanzausfall, Latenz, Region Down), um Fehlertoleranz und Wiederanlauffähigkeit zu prüfen. Ziel ist die Validierung, nicht die Störung. (3, 7)

**Cloud-Region / Multi-Region-Design** – Eine Region umfasst mehrere AZs. Multi-Region verteilt Workloads über Regionen und schützt gegen regionale Ausfälle – bei höherer Latenz, Komplexität und Kosten. (3, 4, 8)

**Crypto Agility** – Organisatorische und technische Fähigkeit, kryptografische Verfahren, Schlüssel und Vertrauensketten über die Zeit auszutauschen. (10)

**DDoS** – Erschöpfung von Ressourcen statt Zerstörung. Resilienz basiert auf kapazitiver Elastizität, Lastverteilung und kontrollierter Degradation. (4)

**Degradationskurve** – Darstellung der Systemleistung L(t) über die Zeit mit Normalbetrieb, Störung, degradiertem Zustand, Recovery und Zielzustand. Kenngrößen: Ausfalltiefe Δ und Wiederherstellungszeit tR. (2)

**Diversität** – Bewusster Einsatz unterschiedlicher Komponenten, Technologien oder Anbieter gegen gemeinsame Fehlerursachen (Common Mode Failures) und importierte Supply-Chain-Risiken. (1, 3, 4)

**Eskalationsschwelle** – Vorab schriftlich festgelegtes Kriterium, ab dem ein Ereignis an die nächste Rolle übergeben werden muss, etwa vom SOC an das CERT oder vom CISO an die Geschäftsleitung, jeweils mit Frist. Ohne Schwelle bleibt ein erkannter Alarm ohne Eigentümer (Fall Target 2013). (6)

**Failover** – Kontrollierter Wechsel auf eine alternative Ressource oder Umgebung. Resilienz entsteht erst durch getestete Umschaltpfade. (3, 4, 7)

**Graceful Degradation** – Kontrolliertes Herunterfahren der Leistung statt Totalausfall, etwa Warteschlange statt Fehlerseite. (3, 4)

**Hybrid-Architektur** – Kombination aus On-Premises und Cloud. Erhöht sowohl den Gefährdungsraum als auch den Resilienzspielraum. (3)

**Immutable Backup** – Backup, das nach Erstellung nicht verändert oder gelöscht werden kann (WORM). Wirksam erst mit Offsite-Lagerung und getesteter Recovery. (4, 7)

**Mandat (des CISO)** – Formale Ausstattung einer Rolle mit Verantwortung, Befugnis und Ressourcen sowie einem Berichtsweg zur Geschäftsleitung. Fehlt eine dieser Seiten, entsteht „Accountability without Authority“: Verantwortung ohne die Mittel, sie wahrzunehmen. (6)

**Microsegmentation** – Feingranulare, softwarebasierte Unterteilung in isolierte Sicherheitszonen bis auf Workload-Ebene; begrenzt laterale Bewegung. (8)

**Redundanz** – Mehrfachvorhaltung kritischer Komponenten gegen den Ausfall einzelner Elemente. Wirkt gegen infrastrukturelle Ausfälle, nicht gegen logische Fehler oder Kompromittierung. (1, 3, 7)

**Reifegradmodell** – Bewertet die geübte Wirksamkeit von Resilienzmaßnahmen vor dem Ereignis, nicht die Existenz von Plänen. (2, 5)

**Resilienz** – Fähigkeit eines Systems, trotz Störungen funktionsfähig zu bleiben, sich rasch zu erholen und sich anzupassen. (1)

**Resilienzzyklus** – Detection → Response → Recovery → Adapt; wiederkehrender Prozess, mit dem eine Organisation Störungen erkennt, bewältigt und daraus lernt. (5)

**Restore-Test** – Nachweis, dass sich Daten aus einer Sicherung tatsächlich zurückspielen lassen. Misst nur einen Teil der RTO; Entscheidung, Bereinigung, Infrastruktur und Abnahme kommen hinzu. (7)

**Shared Responsibility Model** – Der Cloud-Anbieter sichert die Infrastruktur; Daten, IAM-Konfiguration, Backups und Zugänge verantwortet der Kunde. (7, 8)

**Steuerungsebene (Control Plane)** – Verwaltungsschicht, über die Ressourcen angelegt, geändert und gelöscht werden, etwa die Konsole eines Cloud-Anbieters oder die zentrale Serververwaltung. Eine Kopie, die über dieselbe Steuerungsebene gelöscht werden kann wie das Original, ist Redundanz, kein Backup (Fall UniSuper 2024). (7)

**Threat-to-Resilience-Mapping** – Bedrohungen werden nicht mit Präventionsmaßnahmen, sondern mit Resilienzfähigkeiten beantwortet. Ziel ist die Minimierung des Effekts. (4)

**Wiederanlaufreihenfolge** – Reihenfolge, in der Systeme nach einem Ausfall wiederhergestellt werden; sie folgt den technischen Abhängigkeiten (Infrastruktur, Identität und Namensdienste, Datenbanken, Anwendungen, Öffnung für Nutzer), nicht der Sichtbarkeit der Dienste (Fall Universität Gießen 2019). (7)

**Zero Trust** – Sicherheits- und Resilienzkonzept ohne implizites Vertrauen: Jeder Zugriff wird explizit, kontextabhängig und fortlaufend autorisiert. (4, 8)

## OT und KI

**Aktor** – Physisches Element, das auf Steuerbefehle reagiert (Ventil, Motor, Schalter). (9)

**Anomalieerkennung** – Verfahren, häufig KI-basiert, zur Identifikation von Abweichungen vom Normalbetrieb. (9)

**Asset-Inventar** – Vollständige Übersicht aller OT-Komponenten einschließlich Firmware-Versionen und Kommunikationsbeziehungen. (9)

**Cold / Warm / Hot Start** – Wiederanlaufmethoden in OT: vollständiger Neustart ohne Prozesszustände, teilweiser Neustart mit Erhalt von Zuständen, nahtloser Übergang auf redundante Systeme. (9)

**Conduit / Zone** – Nach IEC 62443 abgegrenzte Bereiche mit ähnlichen Sicherheitsanforderungen und die kontrollierten Kommunikationspfade zwischen ihnen. (9)

**Daten-Poisoning** – Manipulation von Trainings- oder Sensordaten, um Entscheidungen eines KI-Systems zu verfälschen. (9)

**Defense-in-Depth** – Kombination mehrerer Schutzschichten. (9)

**Engineering-Workstation** – Arbeitsplatz zur Programmierung von PLCs und SCADA; kritischer Angriffspunkt. (9)

**HAZOP** – Hazard and Operability Study; systematische Gefahrenanalyse technischer Prozesse. (9)

**Human-in-the-Loop** – Der Mensch überwacht oder gibt kritische Entscheidungen frei, insbesondere bei KI-Systemen. (9, 10)

**IT/OT-Konvergenz** – Zusammenwachsen von IT- und OT-Systemen durch Cloud, IIoT und gemeinsame Netze. (9)

**Legacy-System** – Altes, oft nicht mehr aktualisierbares System mit langem Lebenszyklus. (9)

**Model Drift** – Schleichende Veränderung von Datenmustern, die ein Modell unbemerkt ungenau werden lässt. (9)

**Predictive Maintenance** – KI-gestützte Vorhersage von Ausfällen anhand von Sensordaten. (9)

**Prompt-Poisoning** – Manipulation von Eingaben, um generative KI zu unerwünschtem Verhalten zu bewegen. (9)

**Purdue-Modell (ISA-95)** – Referenzmodell, das industrielle Systeme in Ebenen von physischen Prozessen (Level 0) bis zu externen Partnern und Cloud (Level 5) gliedert. (9)

**Wallet DoS** – Angriff, der durch übermäßige API-Nutzung Credits oder Guthaben eines Dienstanbieters aufbraucht und finanziellen Schaden verursacht. (9)

## Bibliografie